

Compliance Risks & How We Tackle Them

O&M Cane Training App — developer working note

Framework: Digital Personal Data Protection Act, 2023 + DPDP Rules, 2025. Not legal advice — a developer's map for build decisions.

The short version

We process data about blind/visually-impaired children in India. Under DPDP that is the most heavily protected category of data there is — the subjects are minors and persons with a disability, so two consent rules (Rule 10 and Rule 11) apply simultaneously. The rules are notified but enforcement of the substantive obligations lands on 13 May 2027, so we have a real runway, not a crisis.

The good news: the app is already built local-first, which sidesteps most of the heavy obligations for now. The risk concentrates in three places — consent proof, the planned session-video-to-cloud step, and (much later) pooling. None of these is a blocker today; all are manageable if we build in the right order.

Timeline — how much runway

- **13 Nov 2025:** DPDP Rules notified. Some parts (the Data Protection Board) live immediately.
- **~Nov 2026:** Intermediate phase (e.g. consent-manager registration provisions).
- **13 May 2027:** The substantive obligations — verifiable guardian consent, children's-data rules, security safeguards, breach notification, retention — become enforceable. This is our real deadline.

Read that as: the data model and consent plumbing should be right well before May 2027, but we are not late today.

The risks, concretely

Mapped to what actually triggers each one in our app, not the generic checklist.

Risk area	What triggers it for us	Exposure
Verifiable guardian consent (Rule 10 + Rule 11)	Every child is a minor AND a person with a disability. Both rules apply at once. Consent must be from a parent/lawful guardian, and "verifiable" means more than a tick-box — identity + guardianship has to be establishable.	Highest. This is the single biggest obligation. Burden of proof is on us to show consent was validly obtained.
"Verifiable" bar is high	Rule 10 contemplates identity/age checks via reliable records or government tokens (DigiLocker). Rule 11 wants guardian status confirmed (court order, National Trust / RPwD-Act authority, or local committee).	High, but mitigated — compliance team owns consent collection. We must store proof that it happened.
No profiling / behavioural tracking of	We collect performance data per child over time. That is fine for the stated educational purpose, but the law prohibits	Low if scope stays "assessment for this child's O&M progress." Rises if data is later mined for cross-child

Risk area	What triggers it for us	Exposure
children	tracking, monitoring, behavioural profiling and targeted ads at children.	profiling without care.
Photo + video = sensitive, identifiable child data	Profile photo (local) and session video (cloud, planned). Video of a disabled child is highly identifiable. Access already restricted to admin — keep it that way.	Medium now (photo only, on-device), High once video goes to cloud.
Cross-border storage (Supabase)	If the Supabase project sits outside India, child data leaves the country. DPDP currently uses a permissive “negative-list” model — transfer is allowed unless the government bars the destination.	Low-Medium today; an avoidable risk. Pick an India region and it largely disappears.
Breach notification (72 hours)	Any personal-data breach triggers a 72-hour clock to the Data Protection Board AND notice to every affected guardian.	Low probability, severe if it happens. Need a written who-does-what before any cloud data exists.
Right to erasure (delete-everywhere)	Guardians can demand deletion. Today deletion is local-only. Once video is in the cloud, a local delete won't remove the cloud copy.	Low now (local delete works), High once cloud is live unless built correctly.
Retention limits	Data must be erased once its purpose is served. We have no retention policy or auto-expiry yet.	Low at pilot scale; becomes real once the dataset grows or pooling starts.
Becoming a Significant Data Fiduciary / pooling	Pooling all teachers' data into one central store raises volume + sensitivity and pushes us toward the heaviest legal tier (DPIA, audits, DPO).	Not now. Deferred with pooling. Flagged so it isn't a surprise later.

What's at stake (penalties)

Penalties are ceilings, applied by the Data Protection Board proportionate to the violation — not automatic fines. They matter mainly because children's-data and breach failures sit at the top end.

Failure	Maximum penalty
Failure to take reasonable security safeguards (breach)	Up to ₹250 crore
Breach of children's-data obligations (incl. consent)	Up to ₹200 crore
Failure to notify a breach to the Board / affected people	Up to ₹200 crore
General / other obligations	Up to ₹50 crore

How we tackle them

1. Consent — record proof, even though compliance collects it

The compliance team obtains parental/guardian consent; that clears the collection burden. But under DPDP the burden of proving valid consent falls on us as the data fiduciary. “We think a form was signed” is not a defence.

- Add a per-child consent record to the profile schema: obtained (yes/no), who obtained it, date, and (later) which guardian. This is the “no-regret” field — cheap now, painful to retrofit after data exists.
- Treat it as a hard gate: no session video is captured or uploaded for a child until the consent flag is set.
- Keep the consent record traveling with the data — it must be exportable alongside the records (CSV already carries demographics; add consent columns).

2. Keep it local-first as long as possible

Everything except session video already lives on one device behind the Store seam. That is genuinely the strongest privacy posture we can have — data that never leaves the device is data we can't breach, mis-transfer, or fail to delete remotely. Don't move anything to the cloud that doesn't have to be there. Only video has to.

3. Session video — build the cloud step carefully

- Pick an India-region Supabase project. This neutralises the cross-border question entirely — a one-time setup choice, not ongoing work.
- Restrict bucket access to the admin only (already the decision). No public URLs; use signed, expiring links.
- Build delete-everywhere from day one: deleting a record or a child must delete the cloud video too, not just the local pointer. Retrofitting erasure is how right-to-erasure obligations get missed.
- Decide the offline-upload behaviour (immediate vs queue-and-retry) before writing the uploader — it changes the failure-handling design.

4. Security safeguards — proportionate, written down

- On-device: the data sits in the app's storage; rely on device lock/PIN for the pilot and say so explicitly.
- Cloud (when live): access controls + signed links + encryption-at-rest (Supabase provides this). Keep processing logs — the rules expect a minimum retention of processing records.
- Write a one-page “if there's a breach” note now: who is contacted, who notifies the Board within 72 hours, how guardians are reached. Cheap insurance; required once cloud data exists.

5. Retention — set a purpose and an expiry

State the purpose (“assessing and tracking this child's O&M progress”) and a retention period tied to it (e.g. erase a fixed period after the child leaves the programme). Even a documented manual policy satisfies the principle at pilot scale; automate later.

6. Pooling — don't trip the heavy tier early

Pooling all teachers' data into one central store is what would push us toward Significant-Data-Fiduciary territory (DPIAs, audits, a DPO) and make consent-before-pooling mandatory. The current sequencing is right: ship local-first + video-to-Supabase now, turn on pooling only when it's greenlit and consent infrastructure is in place. Keep it behind the seam so it stays a contained change.

What to actually do, in order

1. Now: add the per-child consent field (cheap, gates everything video). Already next in the build queue.
2. Now: write the one-page breach + retention note. No code, removes a future scramble.
3. Before any cloud work: choose an India-region Supabase project and admin-only bucket access.
4. When building video: delete-everywhere + signed links + the offline-upload decision, all from the start.
5. Later, only if pooling is greenlit: revisit SDF obligations, DPIA, consent-before-pooling, central-vs-backup question.

Bottom line: nothing here blocks the current build. The consent field and an India-region cloud choice are the two moves that prevent almost all of the avoidable risk. The deadline that matters is 13 May 2027.